

STATE OF NEW YORK

2613--A

2025-2026 Regular Sessions

IN ASSEMBLY

January 21, 2025

Introduced by M. of A. LUNSFORD, TAPIA, LEVENBERG, GALLAGHER, LASHER, R. CARROLL, SIMON, GLICK, SIMONE, STECK, KASSAY, TORRES, GONZALEZ-ROJAS, BURROUGHS, ROSENTHAL, HEVESI, LAVINE, REYES, McDONALD, SEAWRIGHT, BRONSON, KELLES, LEE, SHIMSKY, GRIFFIN -- read once and referred to the Committee on Health -- recommitted to the Committee on Health in accordance with Assembly Rule 3, sec. 2 -- committee discharged, bill amended, ordered reprinted as amended and recommitted to said committee

AN ACT to amend the public health law, in relation to providing additional protections for sensitive health information and requiring all health information networks, electronic health records systems, and health care providers to provide patients with a right to restrict the disclosures of such patient's health information

The People of the State of New York, represented in Senate and Assembly, do enact as follows:

Section 1. The public health law is amended by adding two new sections 25 and 26 to read as follows:

§ 25. Privacy of information disclosed through health information networks. 1. Definitions. For purposes of this section:

(a) "Business associate" shall have the same meaning as set forth in 45 CFR 160.103.

(b) "Codified sensitive information" means patient information that, by associated standard codes commonly used in the exchange of patient information including, but not limited to ICD-10 or SNOMED, can be identified as sensitive information in accordance with subdivision three of this section.

(c) "Disclosure" means the release, transfer, provision of access to, or divulging in any manner of information outside the entity that delivered the health care and the patient who received the care, and such term shall not include any of the exceptions set forth in the definition

EXPLANATION--Matter in italics (underscored) is new; matter in brackets [-] is old law to be omitted.

LBD04417-07-6

1 of "disclosure to any other person" as defined in paragraph (e) of
2 subdivision one of section eighteen of this chapter.

3 (d) "Electronic health records system" means any entity operating in
4 the state of New York that electronically stores or maintains patient
5 information, electronic health records, personal health records, health
6 care claims, or payment and other administrative data on behalf of a
7 health care provider, health care service plan, pharmaceutical company,
8 contractor, or employer.

9 (e) "Health care provider" shall have the same meaning as set forth in
10 paragraph (b) of subdivision one of section eighteen of this title and
11 for purposes of this section shall refer to health care providers that
12 are located in the state of New York and use a health information
13 network to receive, hold or exchange patient information on their
14 behalf.

15 (f) "Health information network" shall mean any entity, including a
16 health information technology developer of certified health information
17 technology, that receives, holds or exchanges patient information in
18 electronic form on behalf of a health care provider and makes such
19 information available to two or more individuals or entities that are
20 unaffiliated with the health care provider for purposes of treatment,
21 payment, or health care operations, as those terms are defined under
22 HIPAA, or a qualified health information network as established under
23 TEFCA, which exchanges patient information on behalf of a health care
24 provider located in the state of New York. An entity may qualify as a
25 "health information network" irrespective of whether such entity
26 receives funding from the department. The term "health information
27 network" shall not include:

28 (i) a health care provider;

29 (ii) an entity that makes patient information available solely:

30 (1) from one health care provider to a single health care provider as
31 part of a referral, prescription, or consultation;

32 (2) as necessary for the payment of a health care claim;

33 (3) among affiliates of a single health care provider;

34 (4) to individuals and entities under contract with the entity who
35 meet the definition of a "business associate" under HIPAA and who proc-
36 ess patient information only as directed by a health care provider and
37 do not disclose patient information; or

38 (5) as necessary to operate clinical data registries, provide organ
39 donation coordination services and other similar services as deemed
40 appropriate by the department in regulation;

41 (iii) a health insurer or a health maintenance organization, when
42 acting as a health insurer, to the extent it exchanges patient informa-
43 tion via HIPAA standard transactions; and

44 (iv) an entity that makes patient information available solely to and
45 between health information networks and has no ability to access, modi-
46 fy, or further disclose patient information, including, but not limited
47 to, the recognized coordinating entity under TEFCA.

48 (g) "HIPAA" means the Health Insurance Portability and Accountability
49 Act of 1996 and its implementing regulations at 45 C.F.R. Parts 160,
50 162, and 164.

51 (h) "Non-codified sensitive information" means patient information
52 that contains or reveals sensitive information, but that is not associ-
53 ated with standardized codes and shall include, but is not limited to
54 notes, visit summaries, laboratory results and images.

55 (i) "Patient information" shall have the same meaning as set forth in
56 paragraph (e) of subdivision one of section eighteen of this chapter.

1 (j) "Qualified person" shall have the same meaning as set forth in
2 paragraph (g) of subdivision one of section eighteen of this title.

3 (k) "Sensitive information" means patient information that contains or
4 reveals reproductive health services as defined in paragraph (a) of
5 subdivision one of section sixty-five hundred thirty-one-b of the educa-
6 tion law, gender-affirming care as defined in paragraph (c) of subdivi-
7 sion one of section sixty-five hundred thirty-one-b of the education
8 law, care protected under 42 CFR part 2, diagnosis and treatment for a
9 sexually transmitted infection or HIV, mental health services, alcohol
10 or substance use treatment, and any other health care services deter-
11 mined by the commissioner through regulations, in consultation with
12 health care providers, patient advocates, health information networks
13 and other relevant stakeholders.

14 (l) "TEFCA" means the Trusted Exchange Framework and Common Agreement
15 authorized by the 21st Century Cures Act.

16 2. Patient right to restrict disclosures by health information
17 networks. Within one hundred eighty days from the effective date of this
18 section, the department shall establish rules and regulations requiring
19 any health information network to:

20 (a) provide qualified persons with the means of requesting, without
21 undue effort, restrictions on disclosures of patient information from
22 all health information networks;

23 (b) subject to any regulatory exceptions established by the depart-
24 ment, abide by the terms of a qualified person's requested restriction
25 made under paragraph (a) of this subdivision; and

26 (c) subject to any regulatory exceptions established by the depart-
27 ment, provide or cause to be provided to qualified persons, upon
28 request, a report or notifications detailing disclosures of the applica-
29 ble patient's patient information by or through all health information
30 networks.

31 3. Additional protections for codified sensitive information by health
32 information networks. (a) Within one hundred eighty days from the effec-
33 tive date of this section, the department shall establish rules and
34 regulations, consistent with state and federal law and regulations,
35 including but not limited to article thirty-three of the mental hygiene
36 law and section twenty-seven hundred eighty-two of this chapter, requir-
37 ing any health information network to:

38 (i) develop the capacity to limit the disclosure of codified sensitive
39 information while allowing for the disclosure of a patient's other
40 health information;

41 (ii) when directed by a qualified person, limit user access privileges
42 to codified sensitive information to only those HIPAA covered entities
43 whom the qualified person has specifically authorized to access the
44 codified sensitive information;

45 (iii) provide the ability to automatically disable access to codified
46 sensitive information by an individual or entity located outside the
47 state of New York as directed by a qualified person; and

48 (iv) unless otherwise ordered by a court of competent jurisdiction,
49 notify the qualified person and the provider who rendered the health
50 care documented in the codified sensitive information at least thirty
51 days prior to complying with a civil, criminal, or regulatory inquiry,
52 investigation, subpoena, or summons for codified sensitive information.

53 (b) Such rules and regulations shall also:

54 (i) establish a list of procedure codes, diagnosis codes, medication
55 codes, and other appropriate codes that constitute codified sensitive
56 information;

1 (ii) set forth exceptions to the requirement to block the disclosure
2 of codified sensitive information as required by paragraph (a) of this
3 subdivision, including for disclosures to individuals and entities under
4 contract with a health information network who meet the definition of a
5 "business associate" under HIPAA and who do not re-disclose such patient
6 information;

7 (iii) set forth standards for which sensitive health information that
8 has been restricted pursuant to paragraph (a) of this subdivision can be
9 made available to a treating health care provider to the extent strictly
10 necessary to treat a patient who is experiencing a bona fide medical
11 emergency when the patient or other qualified person is unable to
12 consent to disclosure as a result of such bona fide medical emergency or
13 when the patient is unable to consent and obtaining consent from another
14 qualified person would cause a delay in treatment that would result,
15 within reasonable medical probability, in serious jeopardy to the
16 patient's health or life; provided that any sensitive information made
17 available pursuant to this subparagraph shall not be integrated into the
18 patient's other health care information and shall revert to the quali-
19 fied person's direction under paragraph (a) of this subdivision when the
20 bona fide medical emergency abates or when the patient regains deci-
21 sional capacity or another qualified person is available to consent for
22 them; provided, further that the treating health care provider may
23 include sensitive information that is relevant to the patient's current
24 diagnosis and treatment in their own entry into the patient's electronic
25 health record; and provided, further that health information networks
26 shall maintain, and proactively share with the patient, the name of the
27 treating health care provider who accessed the sensitive health informa-
28 tion, the health care facility they are affiliated with, the date and
29 time of the access, and the nature of the bona fide medical emergency;
30 and

31 (iv) establish guidelines for the authorization necessary to limit
32 disclosure of codified sensitive information pursuant to subparagraphs
33 (ii) and (iii) of paragraph (a) of this subdivision.

34 4. Additional protections for sensitive information by electronic
35 health records systems. (a) Within one hundred eighty days of the effec-
36 tive date of this section, the department shall establish rules and
37 regulations, consistent with state and federal law and regulations,
38 including but not limited to article thirty-three of the mental hygiene
39 law and section twenty-seven hundred eighty-two of this chapter, requir-
40 ing any electronic health records system to:

41 (i) develop the capacity to provide qualified persons with the means
42 of requesting, without undue effort, restrictions on disclosures of
43 patient information;

44 (ii) develop the capacity to limit the disclosure of codified sensi-
45 tive information while allowing for the disclosure of a patient's other
46 health information;

47 (iii) when directed by a qualified person, limit user access privi-
48 leges to codified sensitive information to only those HIPAA covered
49 entities whom the qualified person has specifically authorized to access
50 the sensitive information;

51 (iv) provide the ability to automatically disable access to codified
52 sensitive information by an individual or entity located outside the
53 state of New York as directed by a qualified person; and

54 (v) unless otherwise ordered by a court of competent jurisdiction,
55 notify the qualified person and the provider who rendered the health
56 care documented in the codified sensitive information at least thirty

1 days prior to complying with a civil, criminal, or regulatory inquiry,
2 investigation, subpoena, or summons for codified sensitive information.

3 (b) Within one year of the effective date of this section, the depart-
4 ment shall establish rules and regulations, consistent with state and
5 federal law and regulations, including but not limited to article thir-
6 ty-three of the mental hygiene law and section twenty-seven hundred
7 eighty-two of this chapter, requiring any electronic health records
8 system to:

9 (i) develop the capacity to limit the disclosure of non-codified
10 sensitive information while allowing for the disclosure of a patient's
11 other health information;

12 (ii) when directed by a qualified person, limit user access privileges
13 to non-codified sensitive information to only those HIPAA covered enti-
14 ties whom the qualified person has specifically authorized to access the
15 non-codified sensitive information;

16 (iii) provide the ability to automatically disable access to non-codi-
17 fied sensitive information by an individual or entity located outside
18 the state of New York as directed by a qualified person; and

19 (iv) unless otherwise ordered by a court of competent jurisdiction,
20 notify the qualified person and the provider who rendered the health
21 care documented in the non-codified sensitive information at least thir-
22 ty days prior to complying with a civil, criminal, or regulatory
23 inquiry, investigation, subpoena, or summons for non-codified sensitive
24 information.

25 (c) The rules and regulations required by paragraphs (a) and (b) of
26 this subdivision shall also:

27 (i) set forth standards for which sensitive health information that
28 has been restricted pursuant to paragraph (a) of this subdivision can be
29 made available to a treating health care provider to the extent strictly
30 necessary to treat a patient who is experiencing a bona fide medical
31 emergency when the patient or other qualified person is unable to
32 consent to disclosure as a result of such bona fide medical emergency or
33 when the patient is unable to consent and obtaining consent from another
34 qualified person would cause a delay in treatment that would result,
35 within reasonable medical probability, in serious jeopardy to the
36 patient's health or life; provided that any sensitive information made
37 available pursuant to this subparagraph shall not be integrated into the
38 patient's other health care information and shall revert to the quali-
39 fied person's direction under paragraph (a) of this subdivision when the
40 bona fide medical emergency abates or when the patient regains deci-
41 sional capacity or another qualified person is available to consent for
42 them; provided, further that the treating health care provider may
43 include sensitive information that is relevant to the patient's current
44 diagnosis and treatment in their own entry into the patient's electronic
45 health record; and provided, further that health information networks
46 shall maintain, and proactively share with the patient, the name of the
47 treating health care provider who accessed the sensitive health informa-
48 tion, the health care facility they are affiliated with, the date and
49 time of the access, and the nature of the bona fide medical emergency;

50 (ii) set forth exceptions to the requirement to block the disclosure
51 of codified and non-codified sensitive information as required by para-
52 graphs (a) and (b) of this subdivision, including for disclosures to
53 individuals and entities under contract with a health information
54 network who meet the definition of a "business associate" under HIPAA
55 and who do not re-disclose such patient information; and

1 (iii) establish guidelines for the authorization necessary to limit
2 disclosure of codified and non-codified sensitive information pursuant
3 to subparagraphs (iii) and (iv) of paragraph (a) and subparagraphs (ii),
4 (iii) and (iv) of paragraph (b) of this subdivision.

5 5. Authorization. Notwithstanding section eighteen of this title and
6 subdivision twenty-three of section sixty-five hundred thirty of the
7 education law, a health information network that abides by a qualified
8 person's request to limit disclosure of sensitive information shall not
9 be otherwise required to obtain authorization for the disclosure of
10 patient information, unless authorization is required in accordance with
11 subdivisions three or four of this section, article twenty-seven-F of
12 this chapter, the provisions of section seventeen of this title related
13 to prohibiting the release to an infant patient's parent or guardian of
14 information related to the treatment of such infant patient for venereal
15 disease or the performance of an abortion operation upon such infant
16 patient, section 33.13 of the mental hygiene law, section seventy-nine-l
17 of the civil rights law, section three hundred ninety-four-e of the
18 general business law, 42 CFR part 2, HIPAA, or other relevant federal,
19 state, or local laws.

20 § 26. Privacy of patient information held by health care providers.
21 1. Definitions. For purposes of this section:

22 (a) "Disclosure" means the release, transfer, provision of access to,
23 or divulging in any manner of information outside the entity that deliv-
24 ered the health care and the patient who received the care, and such
25 term shall not include any of the exceptions set forth in the definition
26 of "disclosure to any other person" as defined in paragraph (e) of
27 subdivision one of section eighteen of this title.

28 (b) "Health care provider" shall have the same meaning as set forth in
29 paragraph (b) of subdivision one of section eighteen of this title.

30 (c) "HIPAA" shall have the same meaning as set forth in paragraph (g)
31 of subdivision one of section twenty-five of this title.

32 (d) "Patient information" shall have the same meaning as set forth in
33 paragraph (e) of subdivision one of section eighteen of this title.

34 (e) "Qualified person" shall have the same meaning as set forth in
35 paragraph (g) of subdivision one of section eighteen of this title.

36 (f) "Sensitive information" shall have the same meaning as set forth
37 in paragraph (k) of subdivision one of section twenty-five of this
38 title.

39 2. Patient right to restrict disclosures by health care providers.

40 (a) Within one hundred eighty days from the effective date of this
41 subdivision, the department shall establish rules and regulations that
42 require health care providers to take reasonable steps to:

43 (i) provide qualified persons with the means of requesting
44 restrictions on disclosures of patient information consistent with the
45 obligations imposed by section twenty-five of this title;

46 (ii) notify qualified persons of their right to restrict the disclo-
47 sure of patient information consistent with the capabilities developed
48 by the electronic health records system utilized by the health care
49 provider;

50 (iii) subject to any regulatory exceptions established by the depart-
51 ment, abide by the terms of a qualified person's requested restriction;

52 (iv) unless otherwise ordered by a court of competent jurisdiction,
53 notify the qualified person at least thirty days prior to complying with
54 a civil, criminal, or regulatory inquiry, investigation, subpoena, or
55 summons for sensitive information; and

(v) immediately following any access to sensitive health information pursuant to subparagraph (iii) of paragraph (b) of subdivision three of section twenty-five of this title or subparagraph (i) of paragraph (c) of subdivision four of section twenty-five of this title, document, in writing, and proactively share with the patient, the name of the treating health care provider who accessed the sensitive health information, the health care facility they are affiliated with, the date and time of the access, and the nature of the bona fide medical emergency.

(b) Nothing in paragraph (a) of this subdivision shall create an affirmative obligation on a health care provider to review non-codified data created prior to the effective date of any rules and regulations promulgated pursuant to this section.

(c) The department's rules and regulations shall set forth exceptions to a qualified person's right to restrict disclosures and shall include, at a minimum, exceptions for:

(i) disclosures to public health authorities located in the state of New York in accordance with New York law;

(ii) disclosures necessary to facilitate payment of a health care claim;

(iii) disclosures necessary to ensure that a provider is in compliance with applicable quality of care, licensure or accreditation standards; and

(iv) disclosures strictly necessary to fill a prescription or provide a service.

(d) The department shall establish phase-in periods for health care providers to implement the requirements of this subdivision, taking into account the technical feasibility of implementing restrictions among various sectors, including (i) small health care providers; and (ii) health care providers in sectors that do not typically utilize certified health information technology, as well as the time it takes for the health information systems or electronic health record systems to develop and implement the capacity to segment health records.

(e) The department shall provide guidance to health care providers, including model notices health care providers may use to notify qualified persons to permit them to exercise their rights under this subdivision. Such guidance shall recommend more prominent notices and means for a qualified person to exercise their rights in health care settings where sensitive information is frequently generated as part of patients' health care records.

3. Authorization for a health care provider's disclosure of patient information. Notwithstanding section eighteen of this title and subdivision twenty-three of section sixty-five hundred thirty of the education law, if a health care provider has provided actual notice to a qualified person of such person's right to restrict disclosures of patient information in accordance with the requirements of subdivision two of this section and abides by a qualified person's request to restrict disclosures, no authorization shall be required for such health care provider to disclose a patient's other patient information unless authorization is required by this section or section twenty-five of this title, article twenty-seven-F of this chapter, the provisions of section seventeen of this title relating to prohibiting the release to an infant patient's parent or guardian of information related to the treatment of such infant patient for venereal disease or the performance of an abortion operation upon such infant patient, section 33.13 of the mental hygiene law, section seventy-nine-l of the civil rights law, section three

1 hundred ninety-four-e of the general business law, 42 CFR part 2, HIPAA,
2 or other relevant federal, state, or local laws.

3 4. Authorization for a health care provider's request for patient
4 information. Notwithstanding section eighteen of this title and subdivi-
5 sion twenty-three of section sixty-five hundred thirty of the education
6 law, if a health care provider provides actual notice to qualified
7 persons that it makes routine requests for patient information from
8 other individuals or entities, no authorization shall be required to
9 make a request for patient information unless authorization is required
10 by this section or section twenty-five of this title, article
11 twenty-seven-F of this chapter, the provisions of section seventeen of
12 this title relating to prohibiting the release to an infant patient's
13 parent or guardian of information related to the treatment of such
14 infant patient for venereal disease or the performance of an abortion
15 operation upon such infant patient, section 33.13 of the mental hygiene
16 law, section seventy-nine-l of the civil rights law, section three
17 hundred ninety-four-e of the general business law, 42 CFR part 2, HIPAA,
18 or other relevant federal, state, or local laws.

19 5. Disclosure of de-identified patient information. Nothing in this
20 section shall prohibit a health care provider's disclosure of de-identi-
21 fied patient information for the purposes of quality assurance or
22 improvement activities, clinical trials or research. For purposes of
23 this section, "de-identified" means that the information cannot identify
24 or be made to identify or be associated with a particular individual,
25 directly or indirectly and is subject to technical safeguards and poli-
26 cies and procedures that prevent re-identification, whether inten-
27 tionally or unintentionally, of any individual.

28 6. Penalties. A health care provider shall not be subject to any
29 penalties based solely on a health information network's failure to
30 comply with section twenty-five of this title.

31 § 2. Nothing set forth in this act shall be construed as creating,
32 establishing, or authorizing a new private cause of action by an
33 aggrieved person against a health information network, electronic health
34 records system, or health care provider who has violated, or is alleged
35 to have violated, any provision of this act.

36 § 3. Severability. If any provision of this act, or any application of
37 any provision of this act, is held to be invalid, or ruled to violate or
38 be inconsistent with any applicable federal law or regulation, that
39 shall not affect the validity or effectiveness of any other provision of
40 this act, or of any other application of any provision of this act. It
41 is hereby declared to be the intent of the legislature that this act
42 would have been enacted even if such invalid provisions had not been
43 included herein.

44 § 4. This act shall take effect immediately.